

KIPUCON 2026 · LIMA, PERÚ · 13 DE MAYO

# Cuando Hackean los Ascensores

*Un paquete. Sin autenticación. Pasajeros atrapados.*

**Sec-Llama | Ciberseguridad OT**

*"Descifrando el Futuro. Honrando el Pasado."*

# QUIÉN SOY

## MICHAEL DAHAN

CEO & Co-Fundador | Sec-Llama | KipuCon

### EXPERIENCIA

- ▶ Veterano de Inteligencia Militar israelí
- ▶ Líder de seguridad ofensiva en LATAM & Israel
- ▶ Dirigió entrenamiento cibernético militar para el sector defensa de Perú

### LO QUE HAGO

- ▶ Operaciones de red team & emulación de adversarios
- ▶ Pruebas de penetración de infraestructura & físicas
- ▶ Desarrollo de malware & exploits
- ▶ Herramientas ofensivas & frameworks C2

### SEC-LLAMA

- ▶ Firma de ciberseguridad ofensiva
- ▶ 4 equipos de pentest: Infra, Web, Móvil, Físico
- ▶ Servicio a empresas & gobierno en LATAM

### KIPUCON

- ▶ Plataforma de conferencias de ciberseguridad en LATAM
- ▶ Evento inaugural: Lima, Perú — Mayo 2026
- ▶ Hoja de ruta multi-país en 6 naciones

# PortSwigger Top 50

#38 · Michael Dahan

portswigger.net/web-security/hall-of-fame

|    |                                                                                                                                                                                       |                          |            |
|----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|------------|
| 38 |  Michael Dahan  | 27 Apr 2026 13:25:17 UTC | 274 of 274 |
| 39 |  Anonymous                                                                                         | 27 Apr 2026 14:25:38 UTC | 274 of 274 |
| 40 |  Mostafa Darwish                                                                                   | 27 Apr 2026 15:34:05 UTC | 274 of 274 |
| 41 |  qwezxcdegen                                                                                       | 27 Apr 2026 16:42:32 UTC | 274 of 274 |
| 42 |  Anonymous                                                                                         | 27 Apr 2026 16:58:14 UTC | 274 of 274 |
| 43 |  Andres Maroto                                                                                     | 27 Apr 2026 18:01:49 UTC | 274 of 274 |
| 44 |  Mikhail Nabiullin                                                                                 | 27 Apr 2026 20:16:13 UTC | 274 of 274 |
| 45 |  Adodemate Tobiloba                                                                                | 27 Apr 2026 20:37:19 UTC | 274 of 274 |
| 46 |  Brandon T. Elliott                                                                                | 27 Apr 2026 20:42:13 UTC | 274 of 274 |
| 47 |  Patrick Sheehan                                                                                   | 27 Apr 2026 22:00:51 UTC | 274 of 274 |
| 48 |  Anonymous                                                                                         | 28 Apr 2026 01:32:34 UTC | 274 of 274 |
| 49 |  Adrian Fernandez Velle                                                                          | 28 Apr 2026 08:51:21 UTC | 274 of 274 |
| 50 |  Roman Nasibullin                                                                                | 28 Apr 2026 10:28:48 UTC | 274 of 274 |

Burp Suite

Web vulnerability scanner

Burp Suite Editions

Vulnerabilities

Cross-site scripting (XSS)

SQL injection

Customers

Organizations

Testers

Company

About

Careers

Insights

Web Security Academy

Blog



# IT Roba Datos. OT Rompe Cosas.

|                                                                                                                                                                                         |  |                                                                                                                                                                    |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>IT — Tecnología de la Información</b><br><br>Tu celular, correo, app bancaria, servidores de la empresa.                                                                             |  | <b>OT — Tecnología Operacional</b><br><br>Ascensores, redes eléctricas, plantas de agua, máquinas industriales.                                                    |
| <b>Cuando hackean IT:</b><br><br>Los hackers roban tus datos — contraseñas, tarjetas de crédito, información personal.<br>¿Grave? Sí. ¿Amenaza inmediata para la vida? Generalmente no. |  | <b>Cuando hackean OT:</b><br><br>Las cosas físicas dejan de funcionar — o hacen algo incorrecto.<br>Apagones, explosiones, personas atrapadas, equipos destruidos. |
| <b>Ejemplos:</b><br><br>Filtraciones de datos · Ransomware en PCs<br>Ataques de phishing · Tarjetas robadas                                                                             |  | <b>Ejemplos:</b><br><br>Corte de red eléctrica · Sabotaje de planta de agua<br>Sabotaje industrial · Bloqueo de ascensores                                         |
| <i>Creado: En la era de internet. La seguridad fue parte del diseño.</i>                                                                                                                |  | <i>Creado: Hace décadas. La seguridad nunca fue parte del diseño.</i>                                                                                              |



# Un Proyecto de Fin de Semana Que Salió Mal.

01

Compró una aspiradora robot de \$2,000 — la DJI Romo.



02

Tuvo una idea divertida: controlarla con su control de PlayStation 5.



03

Usó una herramienta de IA para entender cómo la aspiradora se comunica con internet.

04 EL MOMENTO EN QUE TODO CAMBIÓ

Cuando su app se conectó a los servidores de DJI...  
...6,700 aspiradoras en 24 países empezaron a reportarle.

*No estaba hackeando. El servidor de DJI le entregó todo. Sin preguntar.*

LO QUE PODÍA ACCEDER — SIN NINGÚN PERMISO:

|                                                                                       |                          |                                                |
|---------------------------------------------------------------------------------------|--------------------------|------------------------------------------------|
|    | <b>Cámara en vivo</b>    | del interior de 6,700 hogares ajenos           |
|    | <b>Audio en vivo</b>     | todo lo dicho en esas habitaciones             |
|  | <b>Planos detallados</b> | diseño de cada hogar mapeado por la aspiradora |
|  | <b>Ubicación exacta</b>  | coordenadas GPS vía dirección IP               |

# De la Sala de Estar a la Sala de Control.

| DJI Romo — Dispositivo de consumo |                                             |
|-----------------------------------|---------------------------------------------|
| Cámara                            | Video en vivo de salas ajenas               |
| Micrófono                         | Audio del interior de hogares privados      |
| Plano                             | Diseño 2D del hogar — 24 países             |
| Ubicación                         | Coordenadas GPS vía dirección IP            |
| Control                           | Iniciar / detener / redirigir la aspiradora |



| OT / ICS — Sistema de control industrial |                                                   |
|------------------------------------------|---------------------------------------------------|
| Cámara                                   | Vista en vivo de planta de producción / mina      |
| Datos de sensores                        | Presión, temperatura, gas — lecturas en vivo      |
| Mapa de planta                           | Diseño completo de refinería o subestación        |
| Ubicación                                | Sitio físico de infraestructura crítica           |
| Control                                  | Actuadores, válvulas, PLCs — consecuencias reales |

**CAUSA RAÍZ** Sin lista de invitados en el servidor — una clave de dispositivo válida daba acceso a todos los dispositivos de la red. En una aspiradora: vigilancia. En un sistema industrial: control físico.

Fuente: The Verge / Sammy Azdoufal · Febrero 2026

# 10 Pisos. 3 Ascensores. 1 Vulnerabilidad.

## 01 SCADA

### El Cerebro

Decide qué ascensor va a dónde.  
Verifica el estado 10 veces por segundo.

#### En palabras simples:

*Piensa en él como el control de tráfico aéreo — pero para ascensores.*

## 02 3 PLCs

### Los Controladores

Una minicomputadora por ascensor.  
Ejecuta los comandos que recibe.

#### En palabras simples:

*Piensa en él como el piloto que sigue las órdenes de la torre de control.*

## 03 Modbus/TCP

### El Lenguaje

El protocolo que usan las máquinas para hablar.  
Diseñado en 1979. Sin contraseñas.

#### En palabras simples:

*Piensa en él como un walkie-talkie sin candado — cualquiera puede transmitir.*

#### ⚠ LA VULNERABILIDAD

El registro de fallas del PLC está abierto a cualquiera en la red — sin login, sin contraseña, sin verificación.

# Cuatro Pasos. Sin Candado.

01 VER

## Reconocimiento

"Miramos alrededor"

Nos conectamos a la red de control del edificio — sin contraseña. Vemos los tres ascensores: en qué piso están, qué tan llena está la cola de comandos, su estado actual.

Detalle técnico:

FC=3 · Leer todos los registros Modbus · Sin credenciales

02 SATURAR

## Inundación

"Saturamos la bandeja"

Enviamos 24 solicitudes falsas de piso por segundo a un ascensor. La cola se llena. Cada llamada legítima del sistema del edificio es rechazada.

Detalle técnico:

FC=15 · Escritura Múltiple · Desbordamiento de cola

03 GOLPE

## Inyección de Falla

"Un comando. Listo."

Enviamos un solo comando: establecer el registro de fallas en 'falla crítica'. El ascensor se detiene al instante. Las puertas se bloquean. Los pasajeros quedan atrapados.

Detalle técnico:

FC=6 · Escribir Registro · HR4 = 0x10

04 PERSISTIR

## Persistencia

"Lo mantenemos bloqueado"

Reenviamos el mismo comando cada 2 segundos. El ascensor no puede auto-recuperarse. Queda bloqueado el tiempo que queramos.

Detalle técnico:

FC=6 · Cada 2 segundos · Previene recuperación TTL



# DEMO

## *Hackeo de Ascensores en Acción*

---

Terminal 1 — iniciar el servidor:

```
python elevator_server.py
```

Terminal 2 — lanzar el ataque:

```
python attacker_client.py --persist --delay 3
```

Dashboard: <http://localhost:8080>

KipuCon / WhenElevatorsGetHacked

🔍 Type / to search

<> Code

Issues

Pull requests

Agents

Actions

Projects

Security and quality

Insights

Settings

On April 24 we'll start using GitHub Copilot interaction data for AI model training unless you opt out. [Review this update](#) and manage your preferences in your [GitHub account settings](#).

WhenElevatorsGetHacked

Private

Edit Pins

Watch 0

Fork 0

Star 0

main 1 Branch 0 Tags

Go to file

Add file

<> Code

H3ll0Fri3nd and claude

Initial commit: OT elevator attack demo for KipuCon

00578df · 3 weeks ago 1 Commit

|                    |                                                     |             |
|--------------------|-----------------------------------------------------|-------------|
| Presentation       | Initial commit: OT elevator attack demo for KipuCon | 3 weeks ago |
| .gitignore         | Initial commit: OT elevator attack demo for KipuCon | 3 weeks ago |
| README.md          | Initial commit: OT elevator attack demo for KipuCon | 3 weeks ago |
| USAGE_GUIDE.md     | Initial commit: OT elevator attack demo for KipuCon | 3 weeks ago |
| attacker_client.py | Initial commit: OT elevator attack demo for KipuCon | 3 weeks ago |
| dashboard.html     | Initial commit: OT elevator attack demo for KipuCon | 3 weeks ago |

About

Sec-Llama Talk about OT & SCADA Systems Hacking

Readme

Activity

Custom properties

0 stars

0 watching

0 forks

Audit log

Todos los archivos de la demo disponibles en el repositorio GitHub de KipuCon

Terminales de Demo & Resumen del Panel

OT Cyber Demo

SEC-LLAMA

KIPUCON

Connected

Elapsed: 2:45

UNMUTE

ELV-1

Floor 7

State DOOR\_OPEN

Fault OK

0/8

ELV-2

Floor 5

State IDLE

Fault OK

0/8

ELV-3

Floor 10

State IDLE

Fault OK

0/8

ELV-1 07

ELV-2 05

ELV-3 10

MACHINE ROOM

1

2

3

SCADA

ELV-1

FL:7 DOOR\_OPEN

ELV-2

FL:5 IDLE

ELV-3

FL:10 IDLE

EVENT LOG

01:12:55.432 [ELV-1] ELV-1 | DOORS CLOSING - floor 3

01:12:57.521 [ELV-3] ELV-3 | DOORS CLOSING - floor 9

01:12:57.786 [SCADA] SCADA | CALL floor 10 -> assigned ELV-3 [dist=1] [OK]

01:12:58.038 [ELV-3] ELV-3 | DISPATCH -> floor 10 | direction=UP | from=9

01:12:59.354 [ELV-3] ELV-3 | ARRIVED floor 10

01:12:59.354 [ELV-3] ELV-3 | DOORS OPEN -> floor 10

01:13:01.266 [SCADA] SCADA | CALL floor 3 -> assigned ELV-1 [dist=0] [OK]

01:13:01.328 [ELV-1] ELV-1 | DOORS OPEN -> floor 3

01:13:01.468 [ELV-3] ELV-3 | DOORS CLOSING - floor 10

01:13:03.446 [ELV-1] ELV-1 | DOORS CLOSING - floor 3

01:13:05.123 [SCADA] SCADA | CALL floor 7 -> assigned ELV-2 [dist=2] [OK]

01:13:05.170 [ELV-2] ELV-2 | DISPATCH -> floor 7 | direction=UP | from=5

01:13:07.808 [ELV-2] ELV-2 | ARRIVED floor 7

01:13:07.808 [ELV-2] ELV-2 | DOORS OPEN -> floor 7

01:13:07.963 [SCADA] SCADA | CALL floor 7 -> assigned ELV-2 [dist=0] [OK]

01:13:08.322 [MODBUS] MODBUS | Connection from 127.0.0.1:59015

Windows PowerShell

[01:15:24.560] ELV-1 | ARRIVED floor 8

[01:15:24.560] ELV-1 | DOORS OPEN -> floor 8

[01:15:26.251] SCADA | CALL floor 5 -> assigned ELV-2 [dist=0] [OK]

[01:15:26.300] ELV-2 | DOORS OPEN -> floor 5

[01:15:26.681] ELV-1 | DOORS CLOSING - floor 8

[01:15:27.202] ELV-1 | DOORS OPEN -> floor 8

[01:15:28.413] ELV-2 | DOORS CLOSING - floor 5

[01:15:29.323] ELV-1 | DOORS CLOSING - floor 8

HMI STATUS BOARD

| ELV   | FLOOR | STATE        | QUEUE | FAULT | CYCLES |
|-------|-------|--------------|-------|-------|--------|
| ELV-1 | FL:8  | DOOR_CLOSING | Q:0   | OK    | 425    |
| ELV-2 | FL:5  | IDLE         | Q:0   | OK    | 747    |
| ELV-3 | FL:10 | IDLE         | Q:0   | OK    | 946    |

[01:15:30.562] SCADA | CALL floor 7 -> assigned ELV-1 [dist=1] [OK]

[01:15:30.624] ELV-1 | DISPATCH -> floor 7 | direction=DOWN | from=8

[01:15:31.936] ELV-1 | ARRIVED floor 7

[01:15:31.936] ELV-1 | DOORS OPEN -> floor 7

Windows PowerShell

PS C:\KipuCon\TheOT> python attacker\_client.py --persist --delay 3

Reconocimiento de Red & Descubrimiento de Objetivos

OT Cyber Demo — Live Dashboard

← → ↺

🔒

📄

🌐

🔖

🌟

👤

🔒

🔊

📶

🔍

OT Cyber Demo

SEC-LLAMA

KIPUCON

Disconnected

Elapsed: 2:55

UNMUTE

ELV-1

Floor 9

State MOVING\_DOWN

Fault OK

7/8

ELV-2

Floor 2

State IDLE

Fault OK

0/8

ELV-3

Floor 7

State IDLE

Fault OK

0/8

ELV-1 09

ELV-2 02

ELV-3 07

MACHINE ROOM

10

9

8

7

6

5

4

3

2

1

1

2

3

SCADA

ELV-1

ELV-2

ELV-3

FL:9 MOVING\_DOWN

FL:2 IDLE

FL:7 IDLE

EVENT LOG

01:18:18.556 [ELV-2] ELV-2 | DOORS OPEN ← floor 7

01:18:20.322 [MODBUS] MODBUS | Attack phase set to 2 (FLOOD)

01:18:20.369 [SCADA] SCADA | CALL floor 10 → assigned ELV-3 [dist=0] [OK]

01:18:20.416 [ELV-3] ELV-3 | DOORS OPEN ← floor 10

01:18:20.416 [ELV-1] ELV-1 | DISPATCH → floor 4 | direction=UP | from=1

01:18:20.666 [ELV-2] ELV-2 | DOORS CLOSING — floor 7

01:18:20.885 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:20.948 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.011 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.074 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.136 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.198 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.260 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.322 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.448 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

01:18:21.510 [ELV-1] ELV-1 | CMD BUFFER OVERFLOW — command dropped

ATTACK PHASE

NORMAL

RECON

FLOOD

EXPLOIT

IMPACT

Windows PowerShell

[01:21:01.245] ELV-1 | DOORS OPEN ← floor 9

[01:21:01.916] SCADA | CALL floor 9 → assigned ELV-1 [dist=0] [OK]

HMI STATUS BOARD

| ELV   | FLOOR | STATE          | QUEUE | FAULT | CYCLES |
|-------|-------|----------------|-------|-------|--------|
| ELV-1 | FL:9  | ] DOOR_CLOSING | Q:7   | OK    | 763    |
| ELV-2 | FL:2  | • IDLE         | Q:0   | OK    | 986    |
| ELV-3 | FL:7  | • IDLE         | Q:0   | OK    | 567    |

[01:21:03.364] ELV-1 | DOORS CLOSING — floor 9

[01:21:03.888] ELV-1 | DISPATCH → floor 4 | direction=DOWN | from=9

[01:21:04.080] SCADA | CALL floor 10 → assigned ELV-1 [dist=1] [OK]

DEMO ENDED — shutting down

PS C:\KipuCon\TheOT> python.exe .\elevator\_server.py

Windows PowerShell

PS C:\KipuCon\TheOT>

Inundación de Cola de Comandos & Interrupción de Servicio

OT Cyber Demo — Live Dashboard

← → ↺

http://127.0.0.1:8080

Sign in

OT Cyber Demo

SEC-LLAMA

KIPUCON

Disconnected Elapsed: 2:00 UNMUTE

ELV-1

Floor 4

State IDLE

Fault OK

0/8

ELV-2

Floor 7

State IDLE

Fault OK

0/8

ELV-3

Floor 10

State IDLE

Fault OK

0/8

ELV-1 04

ELV-2 07

ELV-3 10

MACHINE ROOM

10

9

8

7

6

5

4

3

2

1

1

2

3

SCADA

ELV-1 ELV-2 ELV-3

FL:4 IDLE FL:7 IDLE FL:10 IDLE

ATTACKER

EVENT LOG

01:21:14.953 [ELV-3] ELV-3 | DOORS CLOSING - floor 8

01:21:15.563 [SCADA] SCADA | CALL floor 9 → assigned ELV-3 [dist=1] [OK]

01:21:15.579 [ELV-3] ELV-3 | DISPATCH → floor 9 | direction=UP | from=8

01:21:16.897 [ELV-3] ELV-3 | ARRIVED floor 9

01:21:16.897 [ELV-3] ELV-3 | DOORS OPEN ← floor 9

01:21:17.040 [ELV-2] ELV-2 | DOORS CLOSING - floor 6

01:21:17.655 [SCADA] SCADA | CALL floor 3 → assigned ELV-1 [dist=2] [OK]

01:21:17.671 [ELV-1] ELV-1 | DISPATCH → floor 3 | direction=UP | from=1

01:21:17.674 [MODBUS] MODBUS | Connection from 127.0.0.1:56333

01:21:18.189 [MODBUS] MODBUS | Attack phase set to 1 (RECON)

01:21:18.193 [MODBUS] MODBUS | Disconnected 127.0.0.1:56333

01:21:19.019 [ELV-3] ELV-3 | DOORS CLOSING - floor 9

01:21:19.882 [SCADA] SCADA | CALL floor 9 → assigned ELV-3 [dist=0] [OK]

01:21:19.976 [ELV-3] ELV-3 | DOORS OPEN ← floor 9

01:21:20.309 [ELV-1] ELV-1 | ARRIVED floor 3

01:21:20.309 [ELV-1] ELV-1 | DOORS OPEN ← floor 3

ATTACK PHASE

NORMAL

RECON

FLOOD

EXPLOIT

IMPACT

Windows PowerShell

HMI STATUS BOARD

| ELV   | FLOOR | STATE  | QUEUE | FAULT | CYCLES |
|-------|-------|--------|-------|-------|--------|
| ELV-1 | FL:4  | ● IDLE | Q:0   | OK    | 458    |
| ELV-2 | FL:6  | ● IDLE | Q:0   | OK    | 653    |
| ELV-3 | FL:10 | ● IDLE | Q:0   | OK    | 837    |

[01:23:00.799] SCADA | CALL floor 7 → assigned ELV-2 [dist=1] [OK]

[01:23:00.815] ELV-2 | DISPATCH → floor 7 | direction=UP | from=6

[01:23:02.134] ELV-2 | ARRIVED floor 7

[01:23:02.134] ELV-2 | DOORS OPEN ← floor 7

[01:23:02.866] SCADA | CALL floor 4 → assigned ELV-1 [dist=0] [OK]

[01:23:02.901] ELV-1 | DOORS OPEN ← floor 4

[01:23:04.254] ELV-2 | DOORS CLOSING - floor 7

[01:23:05.016] ELV-1 | DOORS CLOSING - floor 4

DEMO ENDED - shutting down

PS C:\KipuCon\TheOT> python.exe .\elevator\_server.py

Windows PowerShell

ATTACK PHASE 1 - PASSIVE RECON (Modbus/TCP scanning)

[01:21:18.189] [ATTACKER] Phase → 1 (RECON)

[01:21:18.189] [ATTACKER] Sending FC=17 (List Unit IDs)...

[01:21:18.190] [ATTACKER] Discovered 3 PLC unit(s): [1, 2, 3]

[01:21:18.190] [ATTACKER] Sending FC=3 to unit 1...

[01:21:18.191] [ATTACKER] Sniffed register dump from ELV-1:

[01:21:18.191] HR0 = 1 (current\_floor)

[01:21:18.191] HR1 = 3 (target\_floor)

[01:21:18.191] HR2 = 0 (door\_status)

[01:21:18.191] HR3 = 1 (direction)

[01:21:18.191] HR4 = 0x00 (fault\_code)

[01:21:18.192] HR5 = 0 (cmd\_queue\_depth)

[01:21:18.192] HR6 = 108 (cycle\_count)

[01:21:18.192] HR7 = 2 (state\_id)

[01:21:18.192] [ATTACKER] State: MOVING\_UP

[01:21:18.192] [ATTACKER] No authentication required - writable registers exposed

Ascensor 1 — Puertas Bloqueadas, Pasajeros Atrapados

OT Cyber Demo

SEC-LLAMA

KIPUCON

Disconnected

Elapsed: 5:00

UNMUTE

ELV-1

Floor 7

State IDLE

Fault OK

0/8

ELV-2

Floor 2

State IDLE

Fault OK

0/8

ELV-3

Floor 10

State DOOR\_OPEN

Fault OK

0/8

ELV-1 07

ELV-2 02

ELV-3 10 ▲

MACHINE ROOM

10

9

8

7

6

5

4

3

2

1

3

1

2

SCADA

ELV-1

ELV-2

ELV-3

FL:7 IDLE

FL:2 IDLE

FL:10 DOOR\_OPEN

EVENT LOG

01:12:55.432 [ELV-1] ELV-1 | DOORS CLOSING - floor 3

01:12:57.521 [ELV-3] ELV-3 | DOORS CLOSING - floor 9

01:12:57.786 [SCADA] SCADA | CALL floor 10 → assigned ELV-3 [dist=1] [OK]

01:12:58.038 [ELV-3] ELV-3 | DISPATCH → floor 10 | direction=UP | from=9

01:12:59.354 [ELV-3] ELV-3 | ARRIVED floor 10

01:12:59.354 [ELV-3] ELV-3 | DOORS OPEN + floor 10

01:13:01.266 [SCADA] SCADA | CALL floor 3 → assigned ELV-1 [dist=0] [OK]

01:13:01.328 [ELV-1] ELV-1 | DOORS OPEN + floor 3

01:13:01.468 [ELV-3] ELV-3 | DOORS CLOSING - floor 10

01:13:03.446 [ELV-1] ELV-1 | DOORS CLOSING - floor 3

01:13:05.123 [SCADA] SCADA | CALL floor 7 → assigned ELV-2 [dist=2] [OK]

01:13:05.170 [ELV-2] ELV-2 | DISPATCH → floor 7 | direction=UP | from=5

01:13:07.808 [ELV-2] ELV-2 | ARRIVED floor 7

01:13:07.808 [ELV-2] ELV-2 | DOORS OPEN + floor 7

01:13:07.963 [SCADA] SCADA | CALL floor 7 → assigned ELV-2 [dist=0] [OK]

01:13:08.322 [MODBUS] MODBUS | Connection from 127.0.0.1:59015

ATTACK PHASE

NORMAL

RECON

FLOOD

EXPLOIT

IMPACT

HMI STATUS BOARD

| ELV   | FLOOR | STATE       | QUEUE | FAULT | CYCLES |
|-------|-------|-------------|-------|-------|--------|
| ELV-1 | FL:7  | ≡ DOOR_OPEN | Q:0   | OK    | 848    |
| ELV-2 | FL:2  | ≡ DOOR_OPEN | Q:0   | OK    | 1543   |
| ELV-3 | FL:9  | ≡ DOOR_OPEN | Q:0   | OK    | 1863   |

[01:17:42.242] ELV-1 | DOORS CLOSING - floor 7

[01:17:42.400] ELV-2 | DOORS CLOSING - floor 2

[01:17:43.750] ELV-3 | DOORS CLOSING - floor 9

[01:17:45.454] SCADA | CALL floor 10 → assigned ELV-3 [dist=1] [OK]

[01:17:45.485] ELV-3 | DISPATCH → floor 10 | direction=UP | from=9

[01:17:46.802] ELV-3 | ARRIVED floor 10

[01:17:46.802] ELV-3 | DOORS OPEN + floor 10

DEMO ENDED - shutting down

PS C:\KipuCon\TheOT> |

Windows PowerShell

PS C:\KipuCon\TheOT> python attacker\_client.py --persist --delay 3 |



Ascensor 2 — Falla en Cascada, Segunda Trampa

OT Cyber Demo — Live Dashboard

http://127.0.0.1:8080

Sign in

OT Cyber Demo

SEC-LLAMA

KIPUCON

Connected

Elapsed: 1:01

UNMUTE

ELV-1

Floor 1

State IDLE

Fault OK

0/8

ELV-2

Floor 4

State MOVING\_UP

Fault OK

7/8

ELV-3

Floor 8

State DOOR\_CLOSING

Fault OK

1/8

MACHINE ROOM

10

9

8

7

6

5

4

3

2

1

ELV-1 01

ELV-2 04

ELV-3 08

SCADA

ELV-1

ELV-2

ELV-3

FL:1 IDLE

FL:4 MOVING\_UP

FL:8 DOOR\_CLOSING

EVENT LOG

01:26:43.165 [ELV-3] ELV-3 | DOORS OPEN + floor 10

01:26:43.196 [ELV-1] ELV-1 | DOORS CLOSING - floor 2

01:26:43.353 [MODBUS] MODBUS | Connection from 127.0.0.1:52247

01:26:43.856 [MODBUS] MODBUS | Attack phase set to 1 (RECON)

01:26:45.283 [ELV-3] ELV-3 | DOORS CLOSING - floor 10

01:26:45.864 [MODBUS] MODBUS | Attack phase set to 2 (FLOOD)

01:26:45.912 [ELV-2] ELV-2 | DISPATCH + floor 1 | direction=DOWN | from=5

01:26:46.430 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.491 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.554 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.617 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.680 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.710 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.710 [SCADA] SCADA | CALL floor 5 -> assigned ELV-2 [dist=0] [REJECTED]

01:26:46.742 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.804 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

Windows PowerShell

[01:27:27.355] ELV-1 | DOORS CLOSING - floor 1

[01:27:27.547] ELV-2 | ARRIVED floor 1

[01:27:27.547] ELV-2 | DOORS OPEN + floor 1

[01:27:29.154] SCADA | CALL floor 8 -> assigned ELV-3 [dist=1] [OK]

[01:27:29.331] ELV-3 | ARRIVED floor 8

[01:27:29.331] ELV-3 | DOORS OPEN + floor 8

[01:27:29.666] ELV-2 | DOORS CLOSING - floor 1

[01:27:30.189] ELV-2 | DISPATCH + floor 9 | direction=UP | from=1

[01:27:31.445] ELV-3 | DOORS CLOSING - floor 8

[01:27:31.969] ELV-3 | DOORS OPEN + floor 8

[01:27:32.748] SCADA | CALL floor 8 -> assigned ELV-3 [dist=0] [OK]

HMI STATUS BOARD

| ELV   | FLOOR | STATE       | QUEUE | FAULT | CYCLES |
|-------|-------|-------------|-------|-------|--------|
| ELV-1 | FL:1  | ● IDLE      | Q:0   | OK    | 178    |
| ELV-2 | FL:3  | ▲ MOVING_UP | Q:7   | OK    | 281    |
| ELV-3 | FL:8  | ≡ DOOR_OPEN | Q:1   | OK    | 455    |

[01:27:34.092] ELV-3 | DOORS CLOSING - floor 8

Windows PowerShell

PS C:\KipuCon\TheOT>

Compromiso Total del Edificio — Todos los Ascensores Bloqueados

OT Cyber Demo — Live Dashboard

http://127.0.0.1:8080

OT Cyber Demo

SEC-LLAMA

KIPUCON

Connected

Elapsed: 0:00

UNMUTE

ELV-1

Floor: 1

State: IDLE

Fault: OK

0/8

ELV-2

Floor: 5

State: IDLE

Fault: OK

0/8

ELV-3

Floor: 10

State: IDLE

Fault: OK

0/8

ELV-1 01

ELV-2 05

ELV-3 10

MACHINE ROOM

10

9

8

7

6

5

4

3

2

1

1

2

3

SCADA

ELV-1

ELV-2

ELV-3

FL:1 IDLE

FL:5 IDLE

FL:10 IDLE

EVENT LOG

01:26:43.165 [ELV-3] ELV-3 | DOORS OPEN + floor 10

01:26:43.196 [ELV-1] ELV-1 | DOORS CLOSING - floor 2

01:26:43.353 [MODBUS] MODBUS | Connection from 127.0.0.1:52247

01:26:43.856 [MODBUS] MODBUS | Attack phase set to 1 (RECON)

01:26:45.283 [ELV-3] ELV-3 | DOORS CLOSING - floor 10

01:26:45.864 [MODBUS] MODBUS | Attack phase set to 2 (FLOOD)

01:26:45.912 [ELV-2] ELV-2 | DISPATCH -> floor 1 | direction=DOWN | from=5

01:26:46.430 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.491 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.554 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.617 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.680 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.710 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.710 [SCADA] SCADA | CALL floor 5 -> assigned ELV-2 [dist=0] [REJECTED]

01:26:46.742 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

01:26:46.804 [ELV-2] ELV-2 | CMD BUFFER OVERFLOW - command dropped

ATTACK PHASE

NORMAL

RECON

FLOOD

EXPLOIT

IMPACT

Windows PowerShell

DEMO ENDED - shutting down

PS C:\KipuCon\TheOT> python.exe .\elevator\_server.py

BUILDING ELEVATOR CONTROL SYSTEM - OT CYBER DEMO (SERVER)

Sec-Llama | KipuCon Conference

Floors: 10 | Elevators: 3 | Recovery: 8.0s TTL

Modbus TCP: port 5020 | Dashboard: http://localhost:8080

[01:29:41.422] ELV-1 | PLC ONLINE | start\_floor=1 | buffer\_size=8

[01:29:41.422] ELV-2 | PLC ONLINE | start\_floor=5 | buffer\_size=8

[01:29:41.422] ELV-3 | PLC ONLINE | start\_floor=10 | buffer\_size=8

[01:29:41.932] SCADA DISPATCHER ONLINE | algo=nearest-car | elevators=3

[01:29:41.932] MODBUS TCP SERVER listening on 127.0.0.1:5020

[01:29:41.932] WEB DASHBOARD at http://localhost:8080

ATTACK PHASE 3 - FAULT REGISTER WRITE (Impact)

[01:27:48.534] [ATTACKER] Phase -> 3 (EXPLOIT)

[01:27:48.536] [ATTACKER] Writing fault\_code=0x10 to ELV-2 HR4 (no auth required on Modbus/TCP)

[01:27:48.536] [ATTACKER] Response: FAULT\_INJECTED

[01:27:48.537] [ATTACKER] Phase -> 4 (IMPACT)

[01:27:48.537] [IMPACT] ELV-2 LOCKED. Passengers trapped. Manual reset required.

[01:27:48.537] [ATTACKER] Attack complete. Disconnecting.

ATTACK COMPLETE - This is why OT network segmentation matters

[01:27:48.538] [ATTACKER] Disconnected

PS C:\KipuCon\TheOT>



# Cuatro Fases. Un Ascensor Bloqueado.

## RECON

### Miramos alrededor

Nos conectamos a la red de control sin credenciales. Leímos todos los registros del PLC — piso, batería, profundidad de cola. Sin activar ninguna alarma.

## INUNDACIÓN

### Saturamos la bandeja

Enviamos 24 comandos de piso por segundo. La cola se desbordó. Las llamadas legítimas del sistema del edificio fueron rechazadas silenciosamente.

## EXPLOIT

### Un comando. Listo.

Escribimos `fault_code=0x10` en el registro HR4. El controlador se bloqueó al instante. Puertas congeladas. Pasajeros atrapados. Tiempo total del ataque: menos de 1 segundo.

## PERSISTIR

### Lo mantuvimos bloqueado

Reescribimos HR4 cada 2 segundos. El ascensor no pudo auto-recuperarse. Sin nuestra intervención, queda bloqueado indefinidamente.

*Sin herramientas especiales de hackeo. Sin vulnerabilidades explotadas. Solo: sin contraseña requerida.*

# **Eso fue una simulación. Pero la técnica es real.**

Estos mismos patrones de ataque ya se han usado para:



Cortar electricidad a 230,000 hogares — por hasta 6 horas



Casi provocar una explosión en una planta petroquímica



Retrasar el programa nuclear de un país por 2 años

# Red Eléctrica de Ucrania — Apagón.

- ▶ Correos de phishing → malware instalado → 6 meses de reconocimiento silencioso
- ▶ Los operadores vieron sus propios cursores moverse, abriendo interruptores
- ▶ El malware KillDisk borró los sistemas de recuperación — forzando restauración manual
- ▶ DDoS telefónico bloqueó a los clientes de reportar el apagón
- ▶ Primer ciberataque confirmado contra una red eléctrica en la historia

*Los atacantes usaron el sistema SCADA exactamente como fue diseñado — solo que no estaban autorizados. Sin exploit de protocolo. Solo: acceso a la red + comandos con apariencia válida.*

# 230,000

clientes  
sin electricidad

# 1–6 horas

restaurado solo por  
reinicio manual de interruptores

# Triton — Diseñado para Matar.

- ▶ Objetivo: Sistema de Instrumentación de Seguridad (SIS) Triconex de Schneider Electric
- ▶ Meta: Desactivar los sistemas de seguridad que previenen fallas catastróficas
- ▶ Ingeniería inversa de un protocolo propietario + explotaron un zero-day en el SIS
- ▶ El SIS detectó el ataque y activó un apagado de emergencia — deteniendo el ataque
- ▶ El DOJ de EE.UU. acusó a un investigador del gobierno ruso en 2022

*El objetivo no era el robo de datos. Era crear las condiciones para una catástrofe física. Los ataques OT pueden ser diseñados para causar pérdida de vidas.*

## PRIMER MALWARE

**diseñado para atacar  
sistemas de seguridad  
industrial**

*Si el SIS no lo hubiera detectado, el siguiente paso era una explosión en una instalación que maneja hidrocarburos inflamables.*

# Stuxnet — La Primera Ciberarma.

|           |                                                                                  |
|-----------|----------------------------------------------------------------------------------|
| OBJETIVO  | PLCs Siemens S7-315/S7-417 controlando centrífugas de uranio IR-1                |
| ATAQUE    | Aceleró rotores a 1,410 Hz y luego desaceleró a 2 Hz — causando falla física     |
| SIGILO    | Grabó 21 segundos de datos normales, los reprodujo en pantallas de operadores    |
| ENTRADA   | Memorias USB llevadas a la instalación aislada por contratistas infectados       |
| ZERO-DAYS | Usó 4 zero-days de Windows simultáneamente — sin precedentes para ningún malware |

~1,000

centrífugas destruidas  
de ~9,000 en Natanz

**Retrasó el programa nuclear  
de Irán 1–2 años**

*Stuxnet envió comandos de control válidos usando protocolos industriales nativos — los PLCs los ejecutaron porque no existía el concepto de autorización. El mismo problema de modelo de confianza que acabamos de demostrar.*

# Todo Ataque OT Comparte el Mismo ADN.

## 1 Sin Autenticación

No se requieren contraseñas ni inicios de sesión. Cualquiera que alcance la red puede controlar cualquier dispositivo. Los comandos se confían ciegamente.

*Modbus, BACnet, DNP3 — ninguno requiere inicio de sesión por diseño.*

## 2 Red Plana

Los sistemas IT y OT comparten la misma red. Compromete una PC, obtén acceso a los PLCs. No hay muro entre la oficina y las máquinas.

*Un solo correo de phishing es todo lo que se necesita.*

## 3 Comandos Legítimos

Los atacantes usan el protocolo exactamente como fue diseñado. No hay nada 'sospechoso' que detectar — parece operación normal.

*No se necesita exploit. Solo: acceso a la red.*

## 4 Daño Físico

Esto no es robo de datos. Es destrucción real de equipos, infraestructura y — en última instancia — riesgo para la vida humana.

*No puedes hacer ctrl+Z a una falla de la red eléctrica.*

*Esto no es solo un problema de Modbus — es una falla del modelo de confianza en la mayoría de los protocolos industriales.*

# Cómo Detener Esto.

*Solo cambios de configuración y red.*

## 01 Segmentación de Red

ESFUERZO: MEDIO

Coloca los dispositivos OT en su propio cuarto cerrado en la red (VLAN). Solo el sistema SCADA puede alcanzar el puerto 502.

**Por qué funciona:** Incluso si un atacante entra a la red de oficinas, no puede alcanzar los PLCs. Esto solo detiene la mayoría de ataques OT.

## 02 Firewall Consciente de OT

ESFUERZO: MEDIO

Un firewall que entiende el lenguaje específico que hablan las máquinas (Modbus, BACnet). Bloquea comandos de escritura no autorizados.

**Por qué funciona:** Herramientas como Claroty y Dragos pueden bloquear comandos de escritura FC=6 de fuentes inesperadas.

## 03 Proteger Registros Críticos

ESFUERZO: BAJO

Bloquea los registros más peligrosos (como HR4 — el código de falla) para que solo el sistema SCADA pueda escribir en ellos.

**Por qué funciona:** Una casilla — que no está marcada por defecto. Previene exactamente el ataque de un solo paquete que acabamos de demostrar.

## 04 Detección de Anomalías

ESFUERZO: BAJO

Monitorea la frecuencia de comandos. Normal: 1–3 comandos por minuto. Nuestro ataque: 24 por segundo. Una simple regla de umbral lo detecta.

**Por qué funciona:** Incluso sin entender protocolos OT, alertas basadas en patrones habrían detectado nuestra fase de inundación de inmediato.

# Cinco Cosas para Llevar a Casa.

## 1 Los sistemas OT están en todas partes y mayormente indefensos

Ascensores, redes eléctricas, plantas de tratamiento de agua, equipos mineros — infraestructura crítica que la mayoría no considera 'hackeable'.

## 2 Los protocolos fueron diseñados para máquinas — no para la era del internet

Modbus tiene 45 años. Fue diseñado para pisos de fábrica aislados. Nunca fue pensado para estar conectado a una red.

## 3 Un solo paquete puede causar daño físico real

Lo demostramos en menos de 60 segundos. Una sola escritura a un registro. Sin herramientas especiales, sin exploits.

## 4 La brecha del defensor se está cerrando — gracias a la IA

Lo que Sammy Azdoufal hizo en un fin de semana con Claude Code antes requería años de experiencia especializada. La población de potenciales atacantes acaba de crecer mucho.

## 5 Pregunta a tus proveedores: ¿cuál es su postura de seguridad OT?

Cualquier dispositivo conectado a un sistema de gestión de edificios es un punto de entrada potencial. La seguridad debe ser parte de la conversación desde el día uno.



# ¿Preguntas?

## *"¿Es esto un vector de ataque real?"*

Sí. ICS-CERT ha publicado alertas sobre escrituras Modbus sin autenticación. El incidente de Oldsmar Water Treatment en 2021 usó el mismo patrón — un atacante se conectó remotamente y cambió los niveles de dosificación química.

## *"¿Cuál es la parte más difícil en la práctica?"*

Obtener acceso de red al segmento OT. Si está correctamente segmentado (una VLAN con firewall), el atacante ni siquiera puede alcanzar el puerto 502. La segmentación de red por sí sola detiene la mayoría de estos ataques.

## *"¿Los ascensores reales usan Modbus?"*

Los controles de ascensores a menudo se integran en Sistemas de Gestión de Edificios mediante PLCs usando Modbus o BACnet. Incluso cuando los ascensores no hablan Modbus directamente, su capa de integración BMS generalmente sí — y esa es la superficie de ataque.

## *"¿Se puede hacer un ataque en cascada a un edificio real?"*

Si los PLCs están en la misma red sin segmentación, sí — cada PLC es direccionable independientemente. Nuestra demo mostró los 3 ascensores bloqueados en menos de 10 segundos.

# Gracias

---

**Sec-Llama**

Expertos en Seguridad Ofensiva · Lima, Perú · LATAM

*"Descifrando el Futuro. Honrando el Pasado."*

---

KipuCon 2026 · Lima, Perú · 13 de Mayo